

ThreatCast PK

Live Crowdsourced Cyberattack Intelligence Map of Pakistan

SOFTWARE DESIGN DOCUMENT

Field	Details
Project Title	Threat Cast PK — Live Crowdsourced Cyberattack Intelligence Map of Pakistan
Submitted By	Abdul Haadi & Yasir Saddique Tanoli
Roll Numbers	[241838] & [241919]
Section	BSCS 4-C
Course	CS-284L Visual Programming Lab
Instructor	Hafiz Obaid Ullah Khan
Document Type	Software Design Document (Conceptual Level)
Submission	Spring 2026

1. Introduction

1.1 Project Overview

Pakistan faces over 500,000 documented cyberattacks annually. The PTA Cybersecurity Report 2024–25 recorded a 17 percent rise in attacks against critical national infrastructure, and NCCIA officials confirmed a 35 percent surge in cybercrime in 2025 alone. Despite this escalating threat landscape, there is currently zero publicly accessible, real-time cyberattack intelligence platform in Pakistan. When an attack strikes a bank, hospital, university, or telecom operator, the response is fragmented — CERT-PK issues text advisories buried in government portals, small organisations have no situational awareness, and security researchers have no way to study the national threat landscape.

ThreatCast PK directly addresses this gap. It is a live, crowdsourced cyberattack intelligence platform that aggregates threat data from open APIs, community reports, and official advisories, and presents it on a real-time animated map of Pakistan. Any user — from a SOC analyst at a major bank to a student at a provincial university — can open a browser and see what is being attacked, where, how severely, and what the sector risk trends look like over time.

1.2 Document Purpose and Scope

This document defines the complete software design for ThreatCast PK at the conceptual modelling level. It covers:

- Functional requirements expressed as user stories across five actor epics
- Non-functional requirements covering six quality dimensions
- Five UML and design diagrams: Use Case Diagram, Domain Model, Class Diagram (Conceptual), Entity Relationship Diagram (Conceptual), and sixteen Sequence Diagrams
- Technology stack, panel access matrix, and future scope

1.3 System Context

ThreatCast PK operates with three categories of data source: community-submitted reports from registered reporters, automated pulls from external threat intelligence APIs (AbuseIPDB and GreyNoise), and admin-injected events derived from CERT-PK advisories. All three sources feed into a common event store. Events are classified by a confidence tier — Verified (API-sourced or admin-injected) or Community Reported (human-submitted and approved) — and only these two tiers appear on the public map. Unverified submissions remain hidden until reviewed.

The platform uses a machine learning microservice for two automated intelligence functions: Isolation Forest anomaly detection for identifying coordinated attack campaigns, and a weighted scoring model for calculating live sector risk levels across six industry sectors.

2. Functional Requirements

All functional requirements are expressed in standard user story format: As a [role], I want to [action] so that [benefit]. Each story is accompanied by explicit acceptance criteria that define the conditions under which the story is considered implemented.

Requirements are grouped into five epics corresponding to the five actor types identified in the system. Roles are hierarchical — each higher role inherits all capabilities of lower roles. The inheritance chain is: System (automated) and Admin (independent) — Reporter inherits Registered User — Registered User inherits Public User.

2.1 Epic 1 — Public User

A public user accesses the platform without registering. They have read-only access to all publicly visible panels.

ID	User Story	Acceptance Criteria
US-01	As a public user, I want to view the live threat map so that I can see what cyberattacks are happening across Pakistan.	Map loads within 3 seconds. Shows only Verified and Community Reported events. Unverified events are hidden from view.
US-02	As a public user, I want to click on a location dot so that I can see the full list of attacks reported at that location.	Clicking a dot opens a detail panel listing each attack with its type, target sector, severity rating, submission date, and confidence tier.
US-03	As a public user, I want to filter the map by time window so that I can focus on recent or historical attack data.	Time window options are: last 1 hour, last 6 hours, last 24 hours, and last 7 days. Selecting a window updates the map instantly without page reload.
US-04	As a public user, I want to see the Threat Pulse live ticker so that I can follow incoming attack events in real time.	The ticker scrolls continuously at the bottom of the map and updates within 2 seconds of a new event being approved. Each entry shows city, attack type, sector, and severity.
US-05	As a public user, I want to read the Glossary so that I can understand cybersecurity terms in plain English or Urdu.	Glossary is publicly accessible without login. It contains definitions for all six attack types used in the system as well as key terms such as confidence tier and sector risk score.
US-06	As a public user, I want to read the About page so that I can understand what ThreatCast PK is and how to use it.	Static page, always accessible without login. Explains platform purpose, confidence tier system, and how to become a reporter.
US-07	As a public user, I want to view the community discussion forum so that I can read conversations about active threats.	Forum is fully readable without login. Posting a message requires a registered account.

2.2 Epic 2 — Registered User

A registered user has created an account via email/password or Google OAuth. They inherit all Public User capabilities and gain access to authenticated features.

ID	User Story	Acceptance Criteria
US-08	As a new visitor, I want to register an account using email and password or Google OAuth so that I can choose my preferred signup method.	Email registration requires a unique username, unique email, and password of at least 8 characters. Google OAuth creates the account automatically on first login using the verified Google profile. Both methods assign the Registered role by default.
US-09	As a registered user, I want to log in using email and password or Google OAuth so that I can access authenticated features.	Email login creates an authenticated session expiring after 24 hours. Google OAuth redirects back to the platform on success. Both methods land on the same role-aware dashboard.
US-10	As a registered user, I want to view and edit my profile so that I can keep my account information current.	Users can update their display name. Email-registered users can update their email. Google-linked accounts cannot independently change their email as it is owned by the external provider. Reputation score and earned badges are visible but cannot be manually edited.
US-11	As a registered user, I want to post in the discussion forum so that I can share threat information with the community.	Posting requires login and an active (non-suspended) account. Every post is publicly attributed to the user's display name. Anonymous posting is not permitted.
US-12	As a registered user, I want to receive in-app notifications so that I am alerted when a major attack event matches my saved preferences.	Users can save up to 3 alert subscriptions. Each subscription defines attack types, cities, sectors, and a minimum severity threshold. Matching events trigger an in-app notification visible in the Notification Center panel. No email is sent.
US-13	As a registered user, I want to request reporter status so that I can begin submitting attack reports.	The request is submitted via the user profile page. The user receives an in-app notification when the admin grants or denies the request.

2.3 Epic 3 — Reporter

A reporter is a registered user who has been granted reporter status by an admin. They inherit all Registered User capabilities and gain the ability to submit attack reports.

ID	User Story	Acceptance Criteria
US-14	As a reporter, I want to submit an attack report so that I can contribute threat intelligence to the platform.	The form requires: attack type (dropdown), target sector (dropdown), city (dropdown), and severity (1 to 5 scale). Source IP and description are optional. A CAPTCHA challenge is required before submission.
US-15	As a reporter, I want the system to automatically check for duplicate reports so that I do not submit an already-reported attack.	If a report with the same city, attack type, and organization exists within the preceding 24 hours, the system displays a this attack has already been reported message and blocks the submission.
US-16	As a reporter, I want my report to be auto-approved when conditions are met so that valid intelligence appears on the map quickly.	Auto-approval is triggered when the reporter's reputation score is 75 or above AND the IP verification confidence score is 80 or above. Reports that do not meet both conditions are routed to the admin moderation queue.
US-17	As a reporter, I want to view my full submission history so that I can monitor the status of each report I have submitted.	The My Reports panel lists every submission with its current status (Pending, Approved, or Rejected), the assigned confidence tier, and the rejection reason if the report was rejected.
US-18	As a reporter, I want my reputation score to reflect the quality of my contributions so that the auto-approval system rewards consistent accuracy.	Each approved report adds 10 points to the reporter's reputation score. Each rejected report deducts 5 points. The score cannot fall below zero.

2.4 Epic 4 — Admin

An admin has full platform access. Admin accounts are not self-registerable and are assigned directly. Admins inherit no standard role chain — their access is independent and unrestricted.

ID	User Story	Acceptance Criteria
US-19	As an admin, I want to view the moderation queue so that I can review reports that did not meet auto-approval conditions.	The queue lists all pending reports with full details including reporter identity, submission time, attack details, and IP verification result. Reports are sorted oldest first.
US-20	As an admin, I want to approve or reject reports from the moderation queue so that only accurate intelligence appears on the map.	Approving a report creates an attack event and pushes it to the live map immediately. Rejecting requires selecting a reason from: Spam, Duplicate, Unverifiable, or Insufficient Detail. Both actions are recorded in the audit log.
US-21	As an admin, I want to grant or revoke reporter status so that I can control who contributes intelligence to the platform.	Admin can promote any Registered user to Reporter or demote any Reporter back to Registered from the User Management panel. The action is logged and the affected user is notified.
US-22	As an admin, I want to suspend a user account so that I can prevent abuse of the platform.	Suspended users cannot log in. The suspension reason is recorded in the audit log. The admin can unsuspend the account at any time.
US-23	As an admin, I want to post Threat Advisories so that I can publish curated writeups on major security incidents.	Each advisory has a title, body text, severity tag, and a list of affected sectors. Published advisories appear on the Threat Advisories page for all registered users. Advisories can be archived when no longer current.
US-24	As an admin, I want to view the complete audit log so that I can review all administrative actions taken on the platform.	The audit log records every approve, reject, suspend, unsuspend, promote, demote, advisory publish, and manual event injection. Each entry shows the action, target entity, performing admin, reason given, and timestamp. The log is read-only and cannot be modified.
US-25	As an admin, I want to manually inject verified events so that I can add confirmed incidents from CERT-PK advisories that were not community-reported.	Manually injected events are immediately tagged as Verified with the admin as source. They appear on the live map instantly. The injection is recorded in the audit log with the source reference.

2.5 Epic 5 — System (Automated)

System-level stories describe automated behaviours that execute without human initiation. These include scheduled background jobs, ML-driven detection, and client resilience logic.

ID	User Story	Acceptance Criteria
US-26	As the system, I want to pull malicious IP data from an external threat database on a schedule so that the map always has API-sourced intelligence regardless of community activity.	The automated pull runs every 6 hours. It retrieves the top 50 malicious IPs targeting Pakistani networks, checks for duplicates, stores new ones as Verified events, and pushes them to the map.
US-27	As the system, I want to detect coordinated attack campaigns so that major campaigns are visually flagged on the map.	When 10 or more events share the same IP range within a 6-hour window, the system creates a ThreatCampaign record and displays a CAMPAIGN DETECTED banner on the map with affected cities highlighted. Alert level is assigned as Medium (10-19 events), High (20-49 events), or Critical (50 or more events).
US-28	As the system, I want to recalculate sector risk scores every 30 minutes so that users always see current risk levels.	The risk engine processes all six sectors. Each sector's score is derived from event count and severity over the last 24 hours. Levels are: Low (0 events), Medium (1 to 5), High (6 to 20), Critical (21 or more, or any Critical-severity event).
US-29	As the system, I want to attempt automatic reconnection when a client connection is lost so that users do not miss live map updates.	The client attempts reconnection every 5 seconds for up to 3 minutes. If reconnection fails after 3 minutes, the interface displays a connection lost message prompting the user to refresh.

3. Non-Functional Requirements

Non-functional requirements define the quality attributes of ThreatCast PK across six dimensions. Unlike functional requirements, which describe what the system does, non-functional requirements describe how well it does it. They are binding constraints that every design and implementation decision must respect.

ID	Category	Requirement Statement
NFR-01	Performance	The live threat map shall load and render all visible events within 3 seconds on a standard 4G mobile connection (10 Mbps equivalent).
NFR-02	Real-Time Latency	A newly approved attack event shall appear on all connected clients within 2 seconds of the approval action being confirmed.
NFR-03	Scalability	The system shall support a minimum of 500 concurrent users without measurable degradation in map load time or event push latency.
NFR-04	Availability	The platform shall maintain 99% uptime during the project evaluation period (May through June 2026).
NFR-05	Security: Authentication	All user passwords shall be stored as salted one-way cryptographic hashes. No plain-text passwords shall exist anywhere in the system. Session tokens shall expire after 24 hours. OAuth credentials from external providers are never stored in the system database.
NFR-06	Security: Input Validation	All user-supplied input shall be validated and sanitized on the server side before processing or storage. Parameterised queries shall be used for all database operations to prevent SQL injection. All output shall be encoded to prevent cross-site scripting.
NFR-07	Security: Secrets Management	All third-party API keys, OAuth client secrets, database connection strings, and session signing keys shall be stored exclusively in server-side environment variables. No secrets shall be committed to source control or embedded in client-side code.
NFR-08	Security: Rate Limiting	A reporter account shall be limited to a maximum of 10 attack report submissions per hour. Submissions beyond this limit shall be rejected with an informative error message and the window shall reset automatically.
NFR-09	Reliability: Graceful Degradation	If the external IP verification service (AbuseIPDB or GreyNoise) is unavailable at the time of a report submission, the submission shall proceed normally. The IP verification step shall be skipped and the report shall be routed to the manual moderation queue rather than failing with an error.
NFR-10	Reliability: Reconnection	If a client loses its real-time connection, the client shall automatically attempt to reconnect at 5-second intervals for a maximum of 3 minutes. If reconnection is unsuccessful after 3 minutes, the interface shall display a clearly visible connection lost message with an option to manually refresh.
NFR-11	Data Integrity: Deduplication	Duplicate event prevention shall be enforced at the database level through a unique constraint on the combination of city, attack type,

ID	Category	Requirement Statement
		organisation name, and 24-hour date window. Application-level checks alone are insufficient.
NFR-12	Data Integrity: Soft Deletes	Rejected reports, deleted discussion posts, and suspended user accounts shall never be permanently removed from the database. All such records shall be soft-deleted using a status flag and shall remain retrievable through the admin audit log.
NFR-13	Usability: Task Completion	A first-time reporter with no prior training shall be able to complete and submit a full attack report within 3 minutes of opening the submission form. All primary user flows shall be completable within 3 navigation steps from the platform homepage.
NFR-14	Usability: Accessibility	All foreground and background colour combinations used in the interface shall meet the WCAG 2.1 Level AA contrast ratio requirements. The platform shall be fully operable on mobile screens with a minimum viewport width of 375 pixels.
NFR-15	Maintainability: Independent Services	The ML microservice (campaign detection and risk scoring) shall be independently deployable and independently restartable. If the ML service is unavailable, all other platform functions including the map, reporting, moderation, and notifications shall continue operating normally.
NFR-16	Maintainability: Configuration	All environment-specific configuration values including database connection strings, API base URLs, and token signing secrets shall be stored in server-side environment configuration files and injected at runtime. No environment-specific values shall be hardcoded in application source code.

3.1 Demonstrability During Evaluation

The following NFRs are directly observable during a live project demonstration and therefore carry additional weight in the evaluation:

- NFR-01 (Performance) — map load time is directly measurable on a mobile device
- NFR-02 (Real-Time Latency) — event push delay can be demonstrated live by approving a report and watching the map update
- NFR-09 (Graceful Degradation) — can be demonstrated by disabling the IP verification service and showing that submissions still succeed
- NFR-14 (Accessibility) — mobile responsiveness is verifiable by resizing the browser window or using a phone

The remaining NFRs (password hashing, session expiry, secrets management, soft deletes, rate limiting) are implementation hygiene requirements verifiable through code review. They do not produce visible demo artefacts but are equally mandatory — a missing requirement in any of these areas constitutes a design deficiency.

4. UML and Design Diagrams

Five categories of diagram have been produced for ThreatCast PK. All diagrams are maintained at the conceptual level. The draw.io source files are named consistently — export each diagram as a high-resolution PNG or SVG and paste it into the placeholder below its description before submission.

4.1 UML Use Case Diagram

Purpose

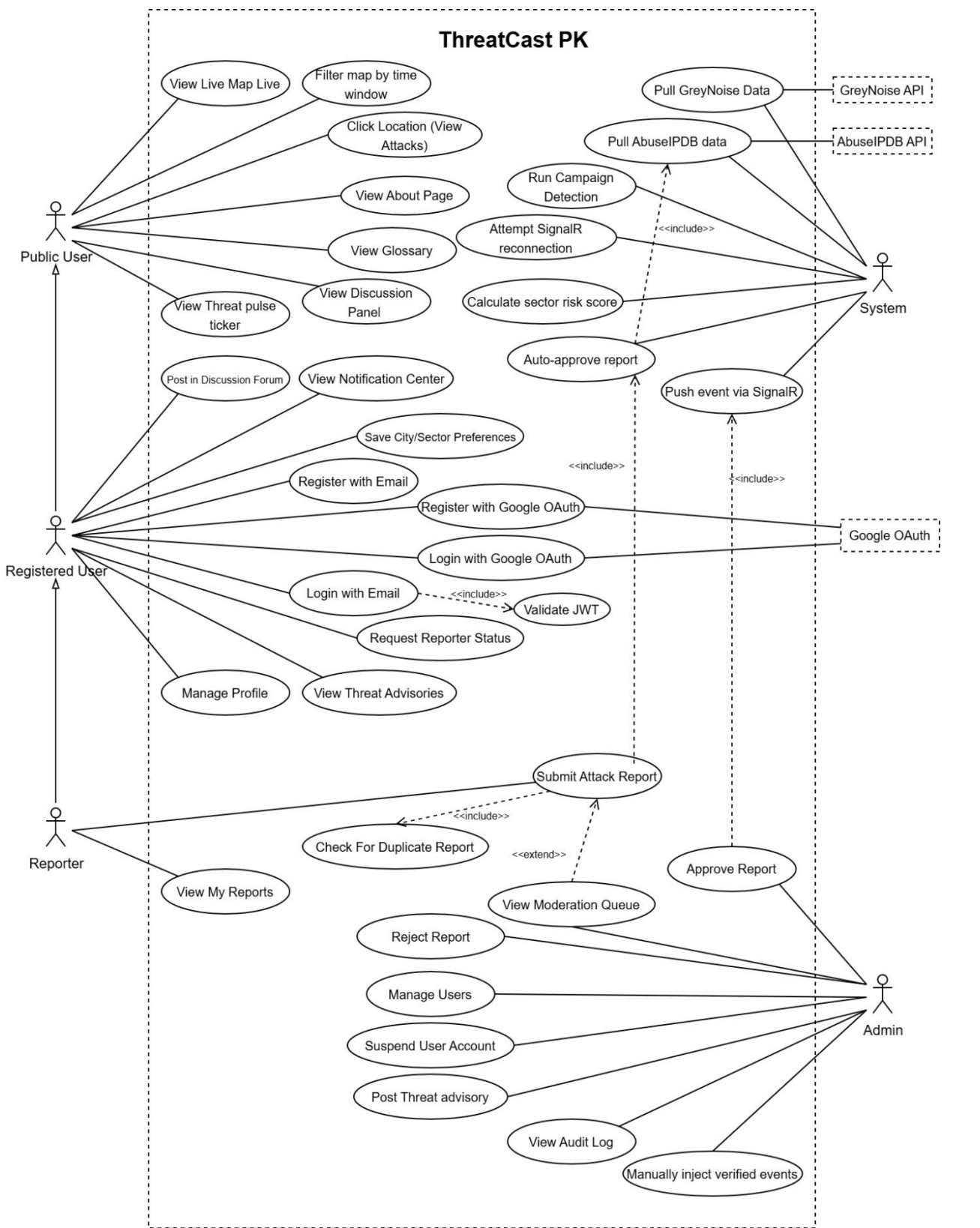
The use case diagram provides a high-level view of the system from the perspective of its actors. It identifies every actor that interacts with ThreatCast PK, every use case (system function) available to each actor, and the structural relationships between use cases.

Actors

- Public User — accesses the map, ticker, glossary, forum (read-only), and about page without authentication
- Registered User — inherits Public User; can post in forum, manage profile, configure alert subscriptions, and request reporter status
- Reporter — inherits Registered User; can submit attack reports and view personal submission history
- Admin — full access including moderation queue, user management, advisory publishing, audit log, and manual event injection
- Scheduled Job (System) — automated actor responsible for external data pulls, campaign detection, and risk score recalculation
- External Auth Provider — external system that handles OAuth-based authentication (Google)
- External Threat Database — external service providing verified malicious IP intelligence (AbuseIPDB, GreyNoise)

Key Relationships

- Submit Attack Report <<include>> Check for Duplicate
- Submit Attack Report <<include>> Verify IP Against External Database
- Verify IP <<include>> Auto-Approve Report
- Approve Report <<include>> Push Event to Live Map
- Submit Attack Report <<extend>> Route to Moderation Queue [when auto-approval conditions are not met]
- Pull External Threat Data <<include>> Save Verified Attack Event
- Reporter generalises Registered User — Registered User generalises Public User



4.2 UML Domain Model

Purpose

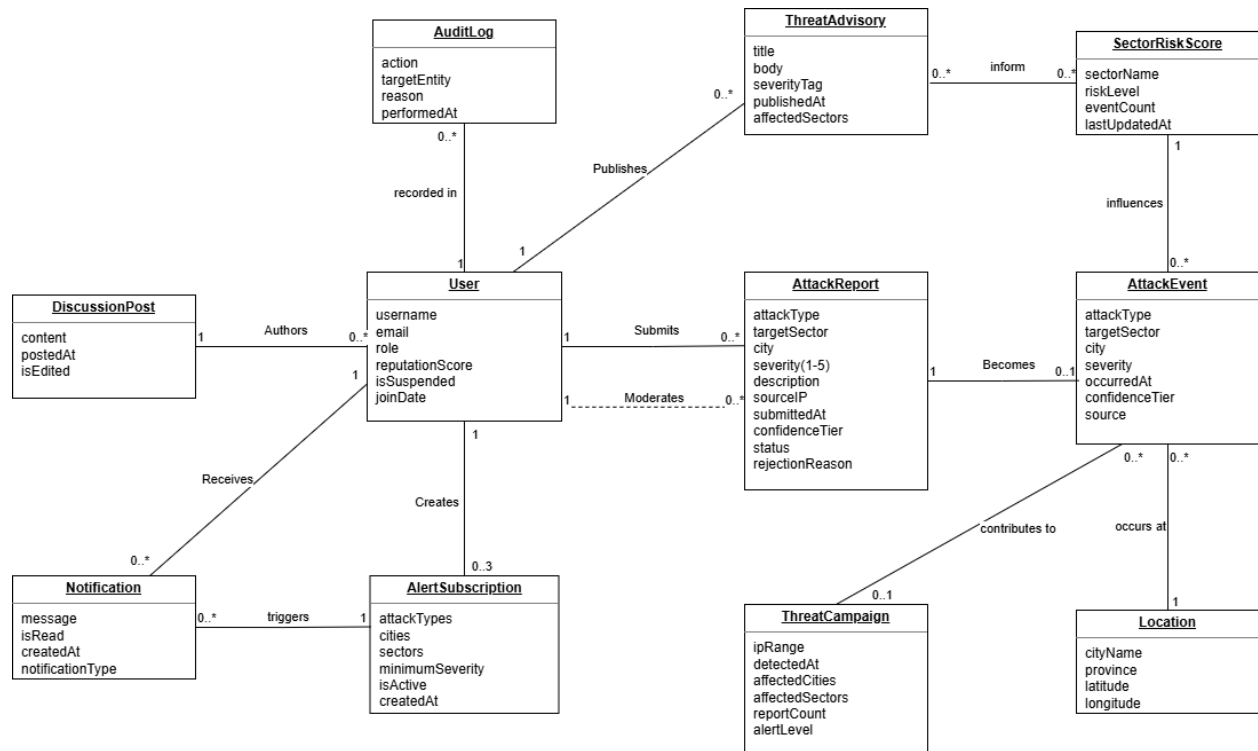
The domain model captures all real-world concepts that exist within ThreatCast PK and the relationships between them. It contains no methods, no data types, no foreign key fields, and no implementation artefacts. A non-technical stakeholder — such as a security analyst, policy maker, or CERT-PK official — should be able to read and fully understand this diagram.

Domain Concepts and Attributes

- User — username, email, role, reputationScore, joinDate
- AttackReport — attackType, targetSector, city, severity, description, sourceIP, submittedAt, confidenceTier, status, rejectionReason
- AttackEvent — attackType, targetSector, severity, occurredAt, confidenceTier, source
- Location — cityName, province, latitude, longitude
- AlertSubscription — attackTypes, cities, sectors, minimumSeverity, isActive, createdAt
- Notification — message, isRead, createdAt, notificationType
- DiscussionPost — content, postedAt, isEdited, editedAt
- ThreatAdvisory — title, body, severityTag, publishedAt, affectedSectors
- AuditLog — action, targetEntity, reason, performedAt
- ThreatCampaign — ipRange, detectedAt, affectedCities, affectedSectors, reportCount, alertLevel
- SectorRiskScore — sectorName, riskLevel, eventCount, lastUpdatedAt

Critical Design Decision — AttackReport vs AttackEvent

AttackReport and AttackEvent are deliberately modelled as two distinct domain concepts. An AttackReport is raw input from a human or automated source — it may be pending review, rejected, or flagged as a duplicate. An AttackEvent is what appears on the public map and only exists after a report has been approved or an API-sourced event has been verified. This separation is the structural foundation of the confidence tier system (Verified vs Community Reported) and ensures that unvetted data never appears to the public as confirmed intelligence.



4.3 UML Class Diagram (Conceptual)

Purpose

The conceptual class diagram defines the structure of ThreatCast PK in terms of its classes, their domain-meaningful attributes, and the relationships between classes including multiplicity constraints. At the conceptual level, no data types, no visibility modifiers (+, -), no ID fields, no foreign key fields, and no methods are included. The diagram answers the question: what are the structural concepts in this system and how many of each can relate to each other?

Classes and Attributes

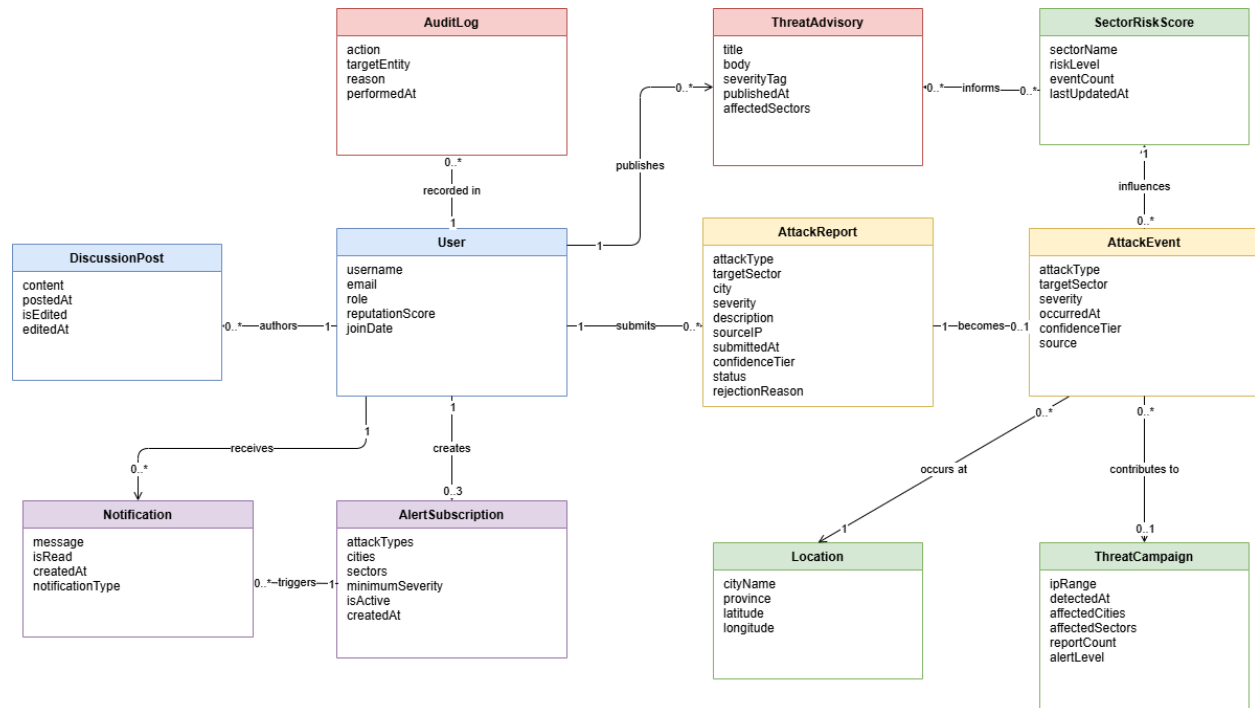
- User — username, email, role, reputationScore, joinDate
- AttackReport — attackType, targetSector, city, severity, description, sourceIP, submittedAt, confidenceTier, status, rejectionReason
- AttackEvent — attackType, targetSector, severity, occurredAt, confidenceTier, source
- Location — cityName, province, latitude, longitude
- AlertSubscription — attackTypes, cities, sectors, minimumSeverity, isActive, createdAt
- Notification — message, isRead, createdAt, notificationType
- DiscussionPost — content, postedAt, isEdited, editedAt
- ThreatAdvisory — title, body, severityTag, publishedAt, affectedSectors
- AuditLog — action, targetEntity, reason, performedAt
- ThreatCampaign — ipRange, detectedAt, affectedCities, affectedSectors, reportCount, alertLevel
- SectorRiskScore — sectorName, riskLevel, eventCount, lastUpdatedAt

Key Multiplicities

- User 1 — 0..* AttackReport (a user submits zero or many reports)
- User 1 — 0..3 AlertSubscription (a user creates at most three subscriptions)
- User 1 — 0..* Notification (a user receives zero or many notifications)
- User 1 — 0..* DiscussionPost (a user authors zero or many posts)
- User 1 — 0..* AuditLog (admin actions are recorded across zero or many entries)
- User 1 — 0..* ThreatAdvisory (an admin publishes zero or many advisories)
- AttackReport 1 — 0..1 AttackEvent (an approved report becomes at most one event)
- AttackEvent 0..* — 1 Location (many events occur at one location)
- AttackEvent 0..* — 0..1 ThreatCampaign (an event may contribute to at most one campaign)
- AttackEvent 0..* — 1 SectorRiskScore (events influence their sector score)
- AlertSubscription 1 — 0..* Notification (a subscription triggers zero or many notifications)
- SectorRiskScore 0..* — 0..* ThreatAdvisory (many-to-many: a risk score informs many advisories and vice versa)

Design Decision — Single User Class

A single User class with a role attribute was chosen over an inheritance hierarchy of Reporter, Admin, and RegisteredUser subclasses. The reason is that the behavioural differences between roles in ThreatCast PK are handled through authorisation checks in the application, not through polymorphism in the domain model. There is no behaviour in the system that requires the compiler or runtime to distinguish a Reporter object from a RegisteredUser object — it is purely a permission level. This decision also matches how role-based access control is implemented in ASP.NET Core Identity, where all users are the same entity and roles are attached as claims.



4.4 Entity Relationship Diagram (Conceptual)

Purpose

The conceptual ERD defines the entities in ThreatCast PK, their domain-meaningful attributes, and the relationships between them expressed using crow's foot notation. At the conceptual level, no data types, no PK or FK labels, no constraint keywords (NOT NULL, UNIQUE, DEFAULT), and no junction tables are present. Junction tables are a physical-level resolution of many-to-many relationships and belong in the physical database schema, not the conceptual model.

Entities and Attributes

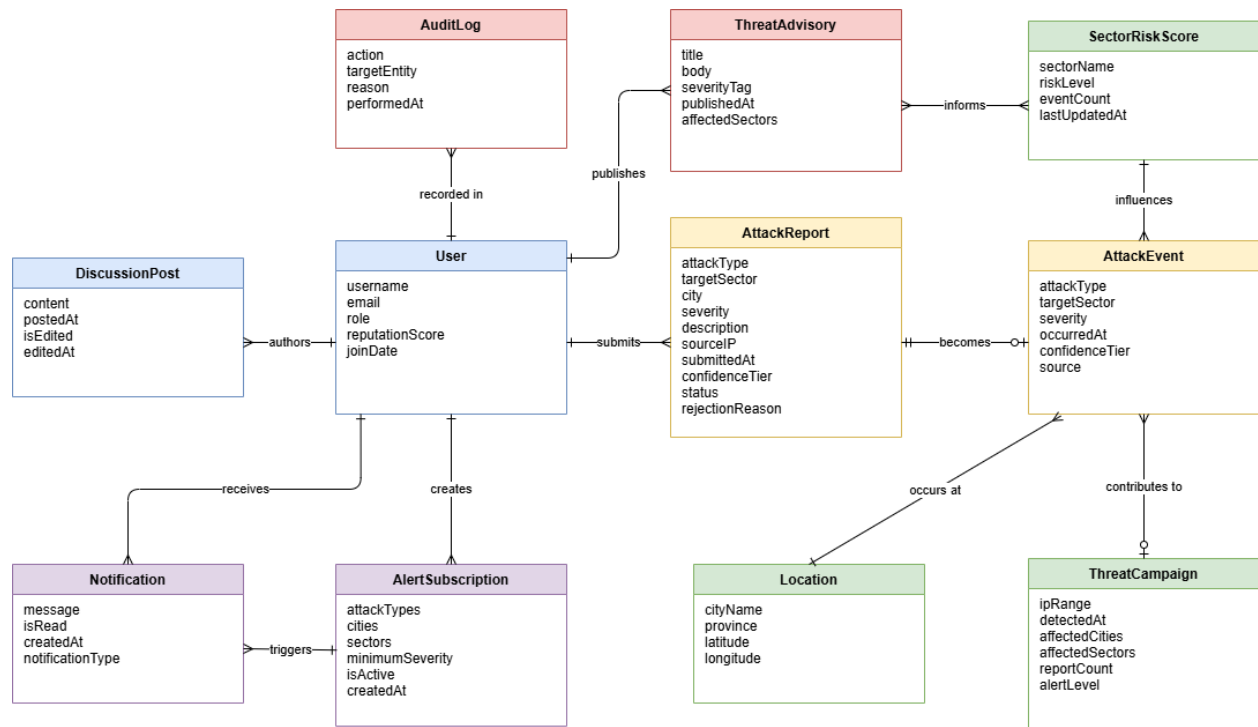
- User — username, email, role, reputationScore, joinDate
- AttackReport — attackType, targetSector, city, severity, description, sourceIP, submittedAt, confidenceTier, status, rejectionReason
- AttackEvent — attackType, targetSector, severity, occurredAt, confidenceTier, source
- Location — cityName, province, latitude, longitude
- ThreatCampaign — ipRange, detectedAt, affectedCities, affectedSectors, reportCount, alertLevel
- AlertSubscription — attackTypes, cities, sectors, minimumSeverity, isActive, createdAt
- Notification — message, isRead, createdAt, notificationType
- DiscussionPost — content, postedAt, isEdited, editedAt
- ThreatAdvisory — title, body, severityTag, publishedAt, affectedSectors
- AuditLog — action, targetEntity, reason, performedAt
- SectorRiskScore — sectorName, riskLevel, eventCount, lastUpdatedAt

Relationships in Crow's Foot Notation

- User ||—o{ AttackReport (one user submits zero or many reports)
- User ||—o{ AlertSubscription (one user creates zero or many subscriptions — max 3 enforced at application level)
- User ||—o{ Notification (one user receives zero or many notifications)
- User ||—o{ DiscussionPost (one user authors zero or many posts)
- User ||—o{ AuditLog (one admin has zero or many audit log entries)
- User ||—o{ ThreatAdvisory (one admin publishes zero or many advisories)
- AttackReport ||—o| AttackEvent (one report becomes zero or one event)
- Location ||—o{ AttackEvent (one location has zero or many events)
- ThreatCampaign ||—o{ AttackEvent (one campaign contains zero or many events)
- SectorRiskScore ||—o{ AttackEvent (one sector score is influenced by zero or many events)
- AlertSubscription ||—o{ Notification (one subscription triggers zero or many notifications)
- SectorRiskScore }o—o{ ThreatAdvisory (many-to-many — a risk score informs many advisories and an advisory is informed by many risk scores)

Note on the Many-to-Many Relationship

The many-to-many between SectorRiskScore and ThreatAdvisory is represented as a direct line at the conceptual level. During physical database design, this resolves to a junction table (SectorRiskAdvisory) containing only the two foreign keys. No attributes belong to this junction because the relationship itself carries no data — it is a pure reference. An associative class would only be justified if the relationship had attributes of its own, such as a relevance score or a linking date.



4.5 Sequence Diagrams

Purpose and Convention

Sixteen sequence diagrams have been produced — one per major system function. Each diagram shows the interaction between actors and system components over time to accomplish a specific goal. All diagrams follow a consistent conceptual convention:

- Participants are named by functional role, not technology (Reporting System not ASP.NET Core API, Account Store not SQL Server, External Auth Provider not Google OAuth)
- Messages describe intent in plain English (save report not INSERT INTO AttackReports, verify password not BCrypt.Verify)
- No HTTP verbs, URL paths, SQL statements, or technology-specific terms appear anywhere in the diagram
- Each diagram includes at least one ALT fragment covering the most important failure or alternate path
- Return messages are shown as dashed arrows pointing back to the caller

Summary of All 16 Sequence Diagrams

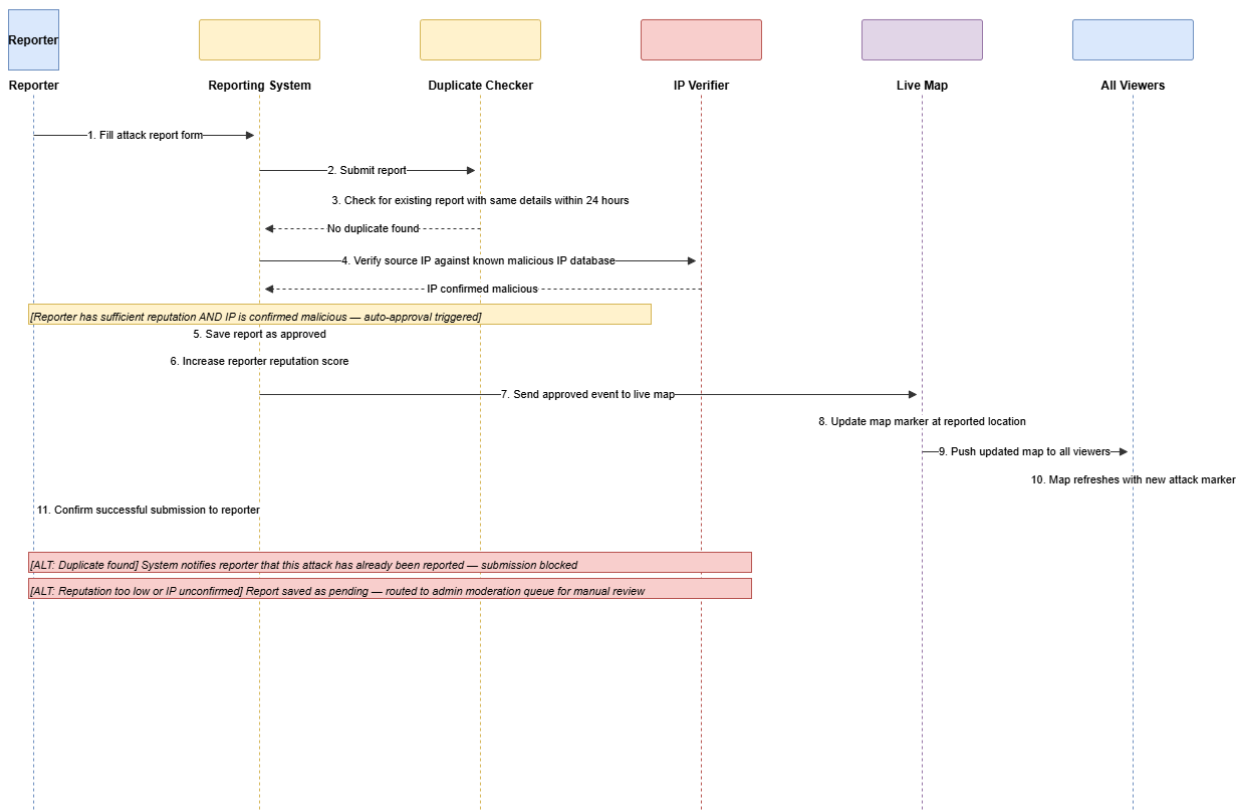
ID	Title	Function Covered
SD-01	Reporter Submits Attack Report	<i>Covers the full submission flow: reporter fills the form, the system checks for a duplicate within the 24-hour window, t...</i>
SD-02	Admin Moderates a Report	<i>Covers manual moderation: admin opens the moderation queue, retrieves pending reports, selects a report, approves or rej...</i>
SD-03	System Pulls External Threat Data	<i>Covers the scheduled background job: the scheduler fires every 6 hours, the threat feed service requests the top 50 mali...</i>
SD-04	Approved Event Triggers Alert Notifications	<i>Covers the notification dispatch flow: a newly approved event is passed to the notification service, all active subscrip...</i>
SD-05	Reporter Views Submission History	<i>Covers the My Reports panel: reporter navigates to the panel, the system retrieves their submissions ordered by most rec...</i>
SD-06	User Registers and Requests Reporter Status	<i>Covers two registration paths in one diagram. ALT A (email and password): user fills registration form, system checks em...</i>
SD-07	Admin Manages User Roles and Accounts	<i>Covers three admin actions in one diagram using ALT fragments. ALT A (grant reporter status): admin selects user, promot...</i>
SD-08	User Creates and Manages Alert Subscription	<i>Covers the full subscription lifecycle. Main flow (create): user opens the notification center, the system checks the ex...</i>
SD-09	Admin Posts Threat Advisory	<i>Covers advisory publishing: admin opens the advisory editor, fills the form (title, body, severity tag, affected sectors...</i>

ID	Title	Function Covered
SD-10	User Posts in Discussion Forum	<i>Covers the forum lifecycle: user opens the forum, existing posts are loaded ordered by most recent, user types a message...</i>
SD-11	Admin Views Audit Log	<i>Covers audit log access: admin opens the panel, all entries are retrieved ordered by most recent, the full log is displa...</i>
SD-12	Admin Manually Injects Verified Event	<i>Covers manual event injection for CERT-PK advisories not yet in the system: admin opens the event injection panel, fills...</i>
SD-13	ML System Detects Coordinated Campaign	<i>Covers the campaign detection pipeline: the scheduled job triggers the campaign detection engine, recent events from the...</i>
SD-14	Sector Risk Score Recalculation	<i>Covers the risk score pipeline: the scheduler triggers the risk score engine every 30 minutes, the engine iterates throu...</i>
SD-15	User Login with Email and Password	<i>Covers email authentication: user enters credentials on the login page, clicks sign in, the system looks up the account ...</i>
SD-16	User Login with Google OAuth	<i>Covers OAuth authentication: user clicks sign in with Google, the login system redirects them to the external provider c...</i>

SD-01 — Reporter Submits Attack Report

Covers the full submission flow: reporter fills the form, the system checks for a duplicate within the 24-hour window, the external IP verifier is queried, the auto-approval threshold is evaluated (reputation 75 or above and IP confidence 80 or above), the report is saved as approved, the reporter reputation score is incremented, and the new event is pushed to the live map for all connected viewers. Includes two ALT fragments: duplicate found (submission blocked with message) and insufficient reputation or IP confidence (report routed to moderation queue).

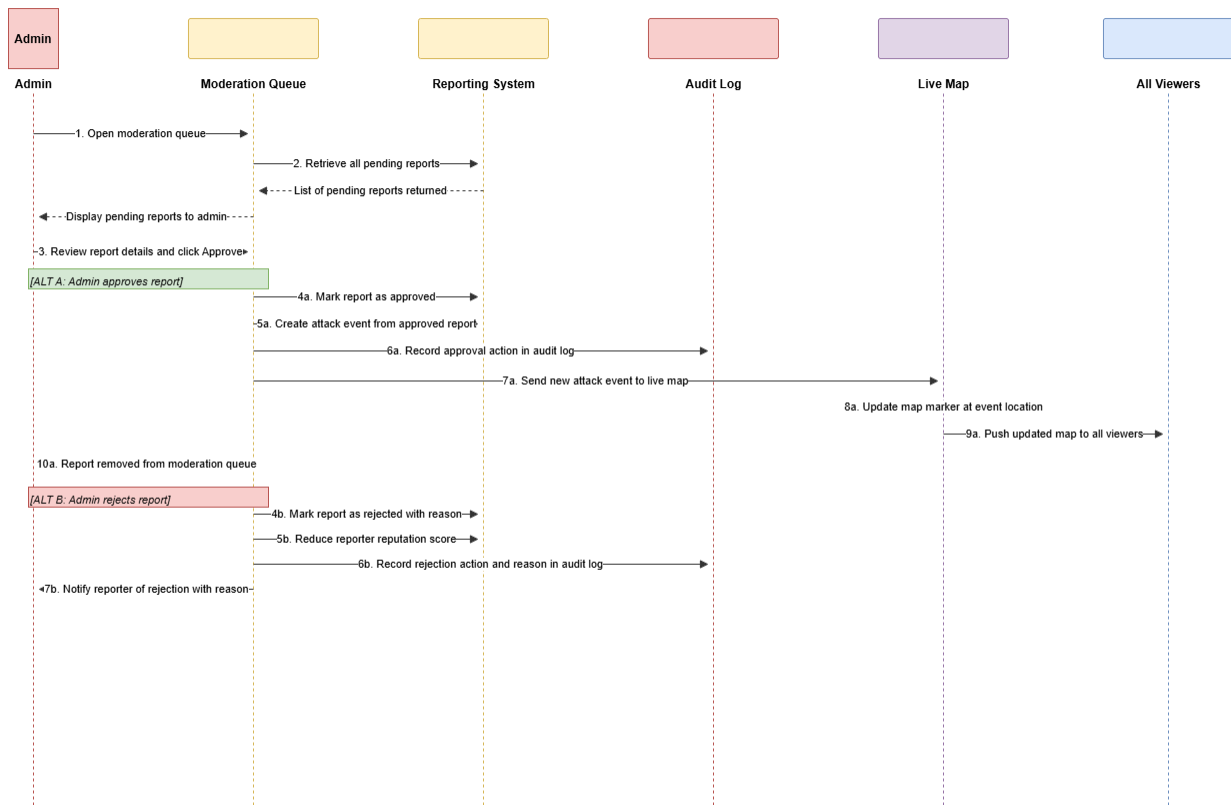
SD-01: Reporter Submits Attack Report (Conceptual)



SD-02 — Admin Moderates a Report

Covers manual moderation: admin opens the moderation queue, retrieves pending reports, selects a report, approves or rejects it. On approval, an attack event is created, the audit log is written, and the event is broadcast to the live map. On rejection, the rejection reason is saved, the reporter reputation is decremented, and the reporter is notified. ALT fragment covers the rejection path in full.

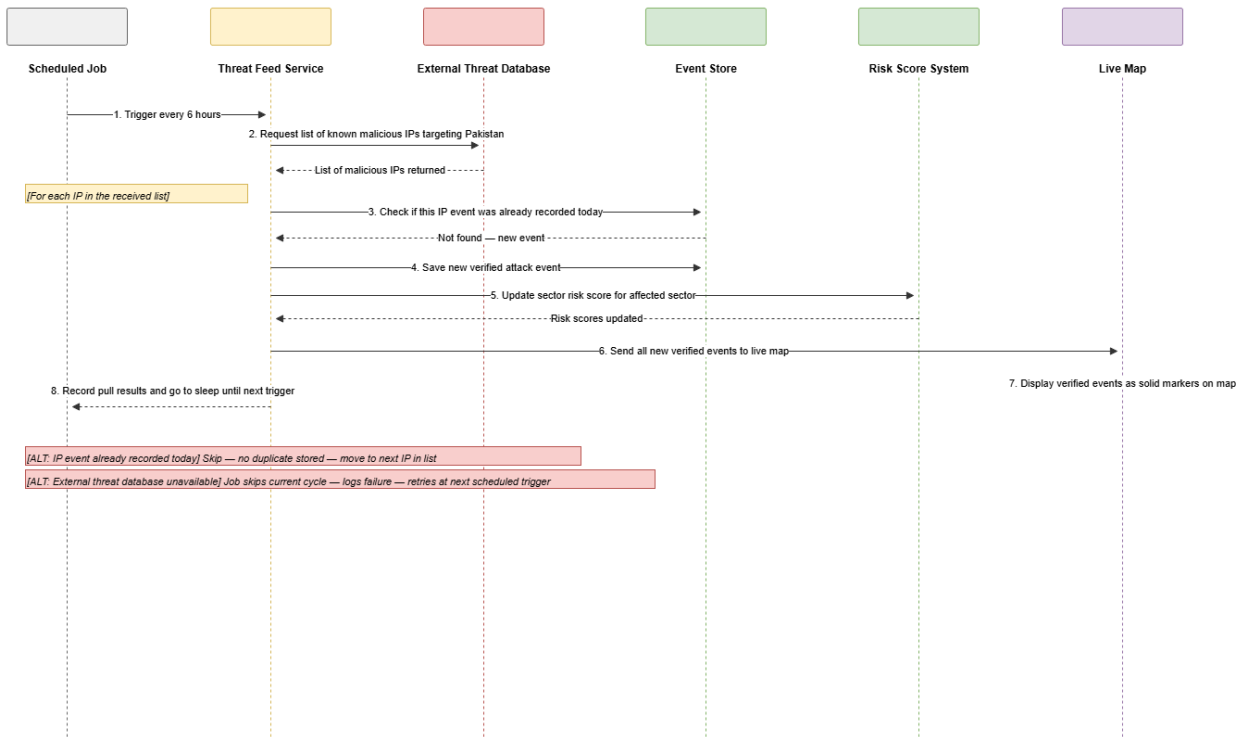
SD-02: Admin Moderates a Report (Conceptual)



SD-03 — System Pulls External Threat Data

Covers the scheduled background job: the scheduler fires every 6 hours, the threat feed service requests the top 50 malicious IPs targeting Pakistan from the external threat database, iterates through each IP, checks for duplicates, saves new verified attack events, updates sector risk scores, and broadcasts all new verified events to the live map. ALT fragments cover the case where an IP was already recorded today (skip) and the case where the external database is unavailable (skip cycle, retry next trigger).

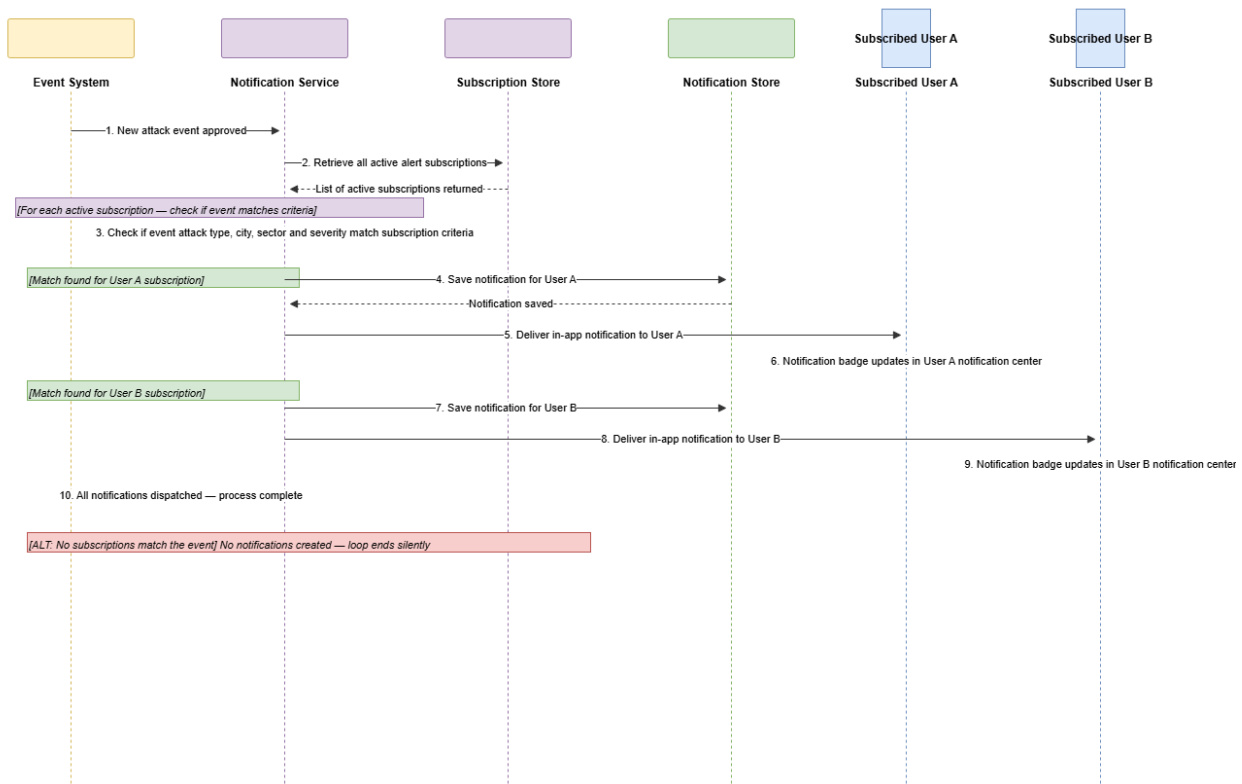
SD-03: System Pulls External Threat Data (Conceptual)



SD-04 — Approved Event Triggers Alert Notifications

Covers the notification dispatch flow: a newly approved event is passed to the notification service, all active subscriptions are retrieved, each is evaluated against the event's attack type, city, sector, and severity, matching subscriptions generate notifications saved to the store and delivered in-app to each subscribed user via the live connection. ALT fragment covers the case where no subscriptions match (silent end).

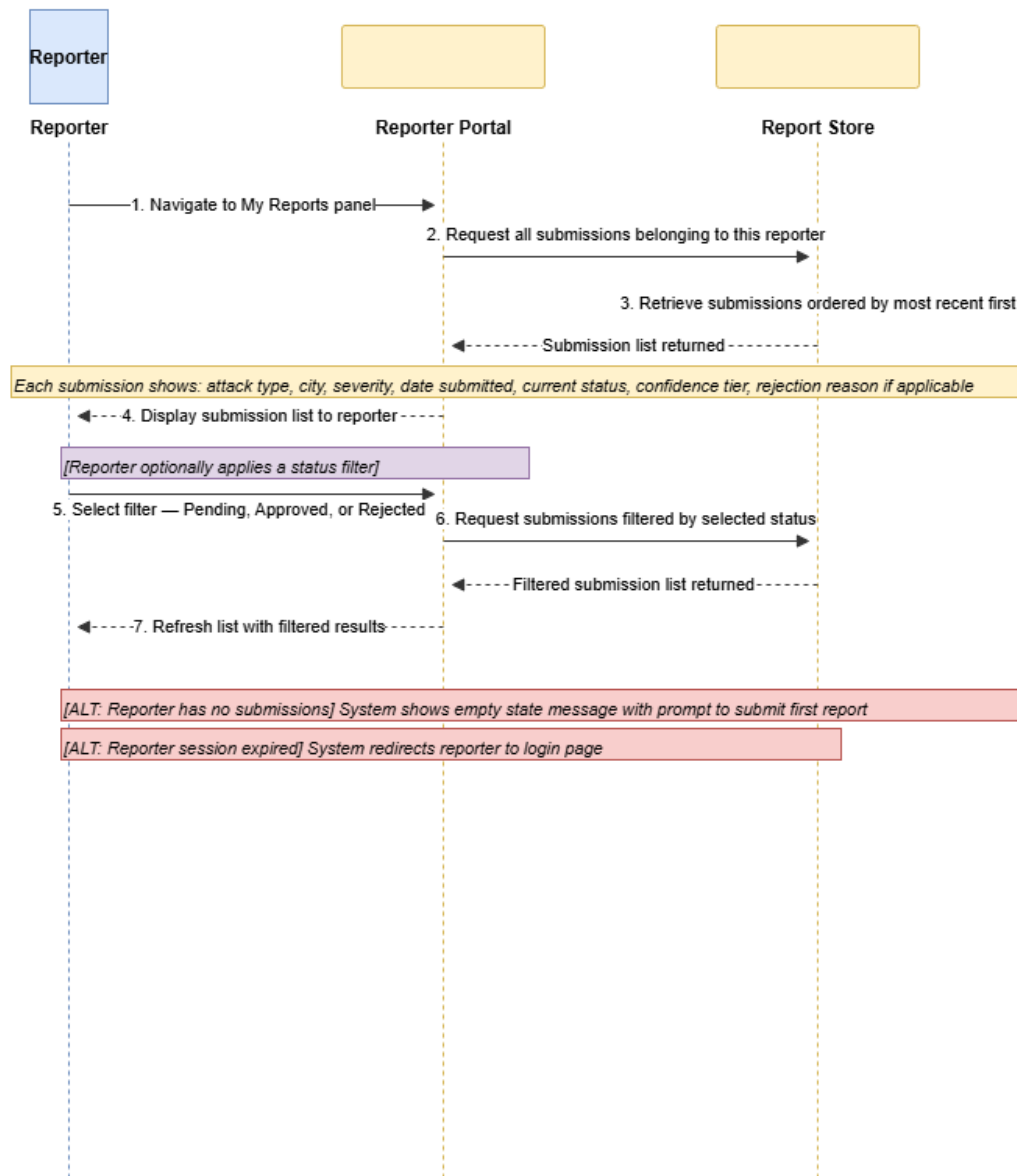
SD-04: Approved Event Triggers Alert Subscription Notifications (Conceptual)



SD-05 — Reporter Views Submission History

Covers the My Reports panel: reporter navigates to the panel, the system retrieves their submissions ordered by most recent, renders the list with each submission showing its status, confidence tier, and rejection reason where applicable, and the reporter optionally applies a status filter (Pending, Approved, or Rejected) triggering a filtered retrieval. ALT fragments cover empty submission history and expired session.

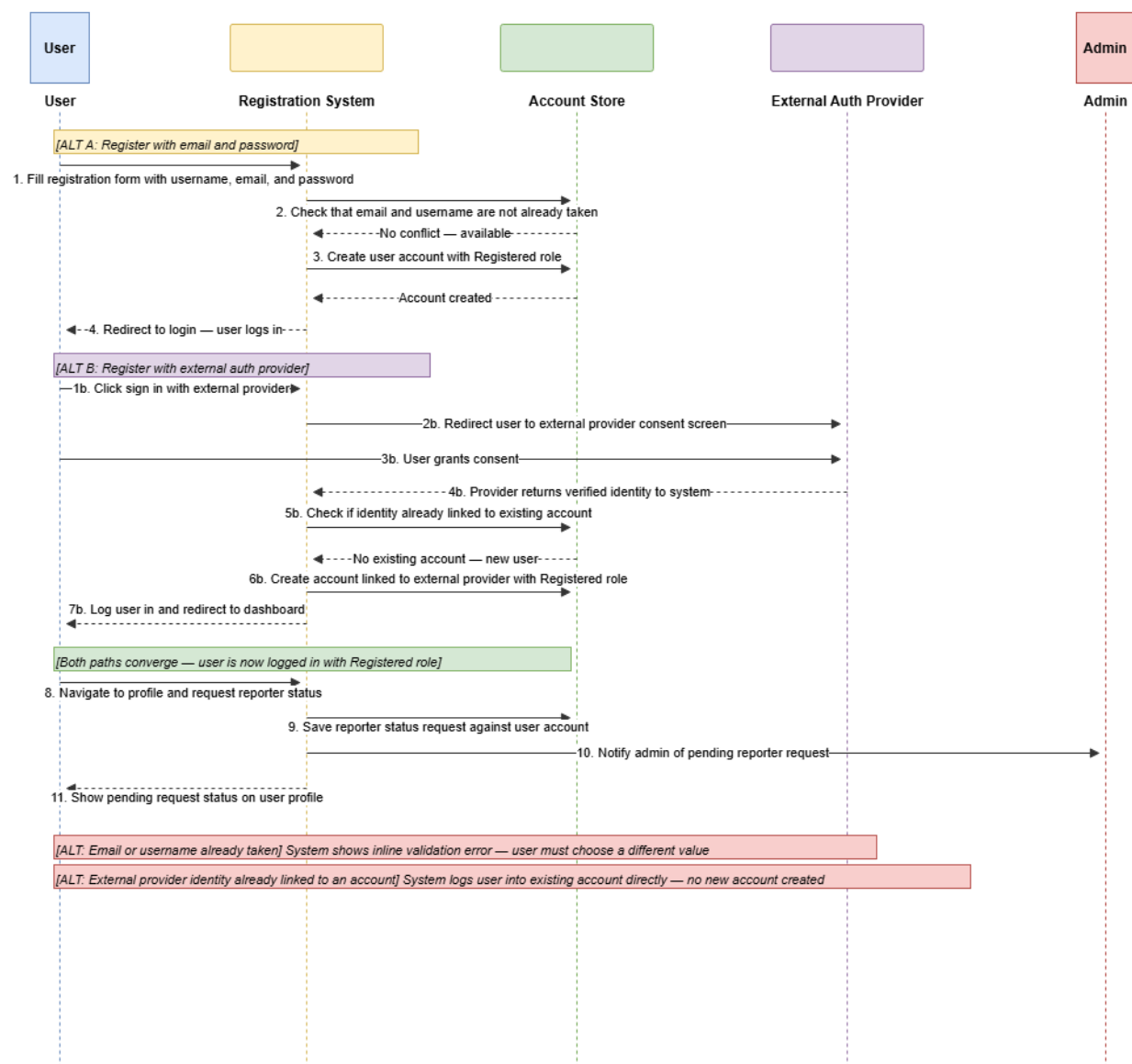
SD-05: Reporter Views Submission History (Conceptual)



SD-06 — User Registers and Requests Reporter Status

Covers two registration paths in one diagram. ALT A (email and password): user fills registration form, system checks email and username uniqueness, creates account with Registered role, redirects to login. ALT B (external OAuth provider): user redirects to consent screen, grants consent, provider returns verified identity, system checks for existing linked account, creates new account with Registered role if not found. Both paths converge at the logged-in state. Final steps show the user requesting reporter status and the admin receiving a notification. ALT fragments cover email or username already taken and existing linked account.

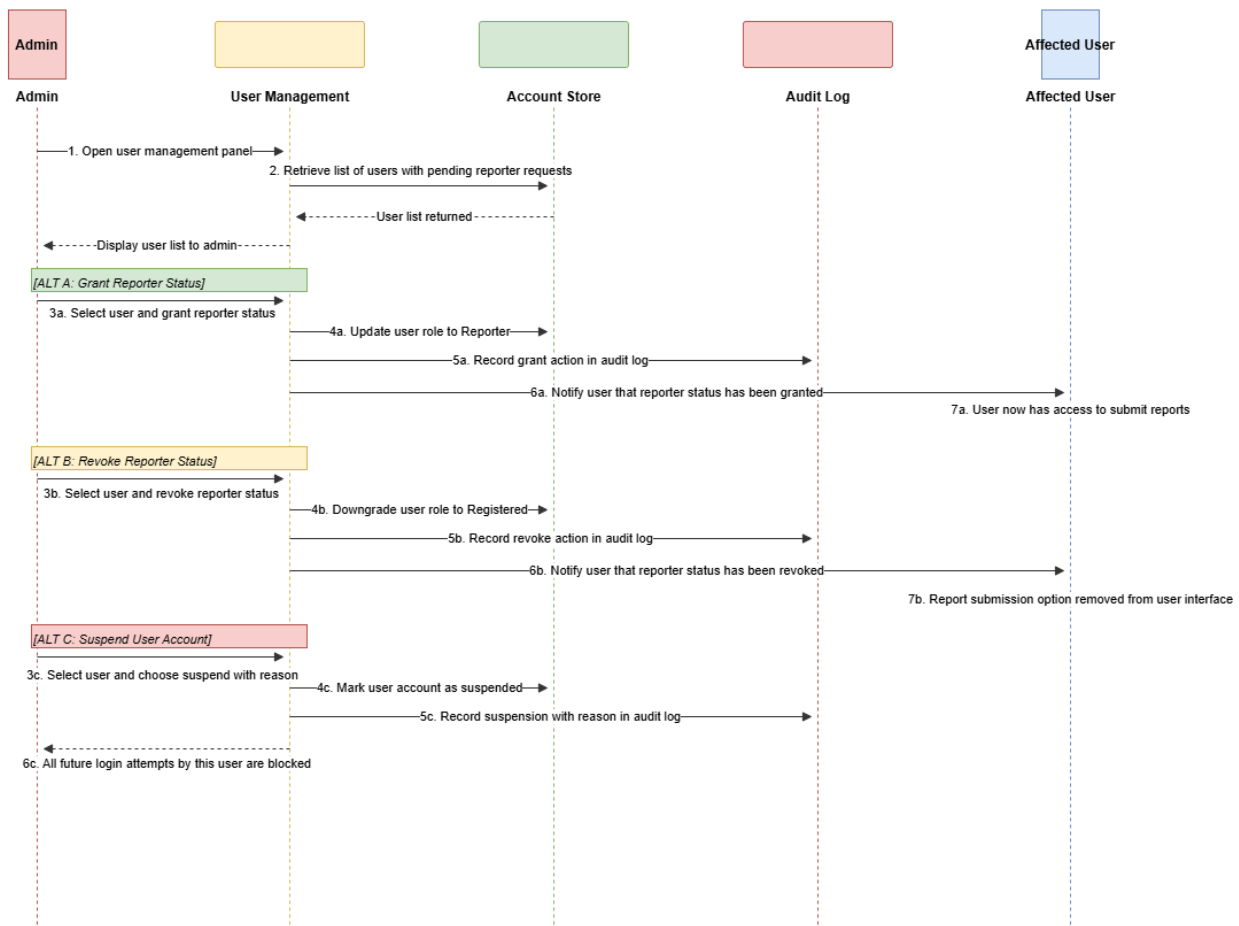
SD-06: User Registers and Requests Reporter Status (Conceptual)



SD-07 — Admin Manages User Roles and Accounts

Covers three admin actions in one diagram using ALT fragments. ALT A (grant reporter status): admin selects user, promotes to Reporter, audit log written, affected user notified and gains access to submit reports. ALT B (revoke reporter status): admin demotes Reporter to Registered, audit log written, user notified and loses report submission access. ALT C (suspend account): admin suspends account with reason, audit log written, all future login attempts by this user are blocked.

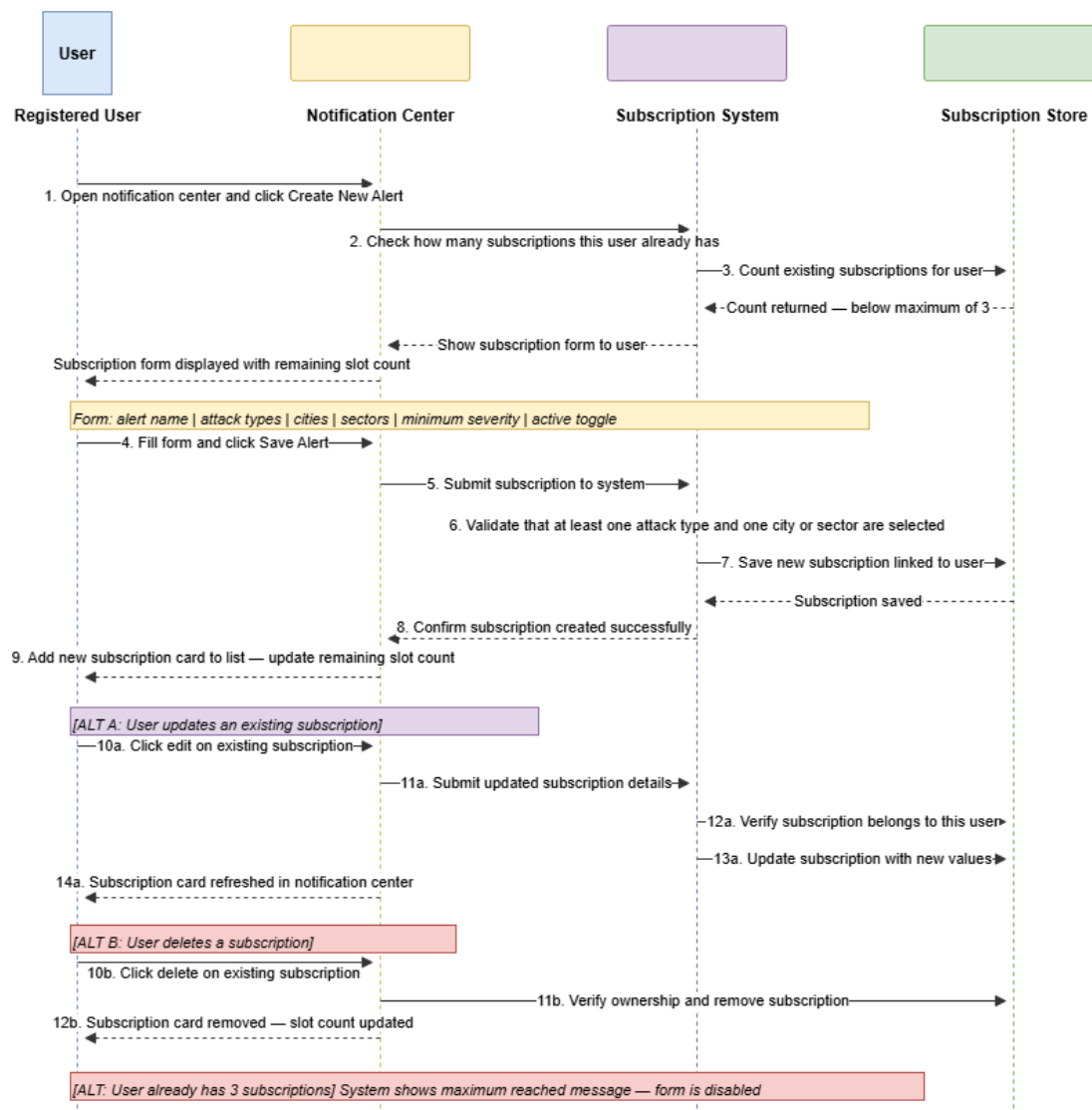
SD-07: Admin Grants or Revokes Reporter Status and Suspends User (Conceptual)



SD-08 — User Creates and Manages Alert Subscription

Covers the full subscription lifecycle. Main flow (create): user opens the notification center, the system checks the existing subscription count against the maximum of 3, the subscription form is displayed with remaining slot count, user fills and submits, the system validates required fields, the subscription is saved and the card appears in the notification center. ALT A (update): user edits an existing subscription, the system verifies ownership and updates the record. ALT B (delete): user deletes a subscription, the system verifies ownership and removes it. ALT fragment covers reaching the maximum subscription limit.

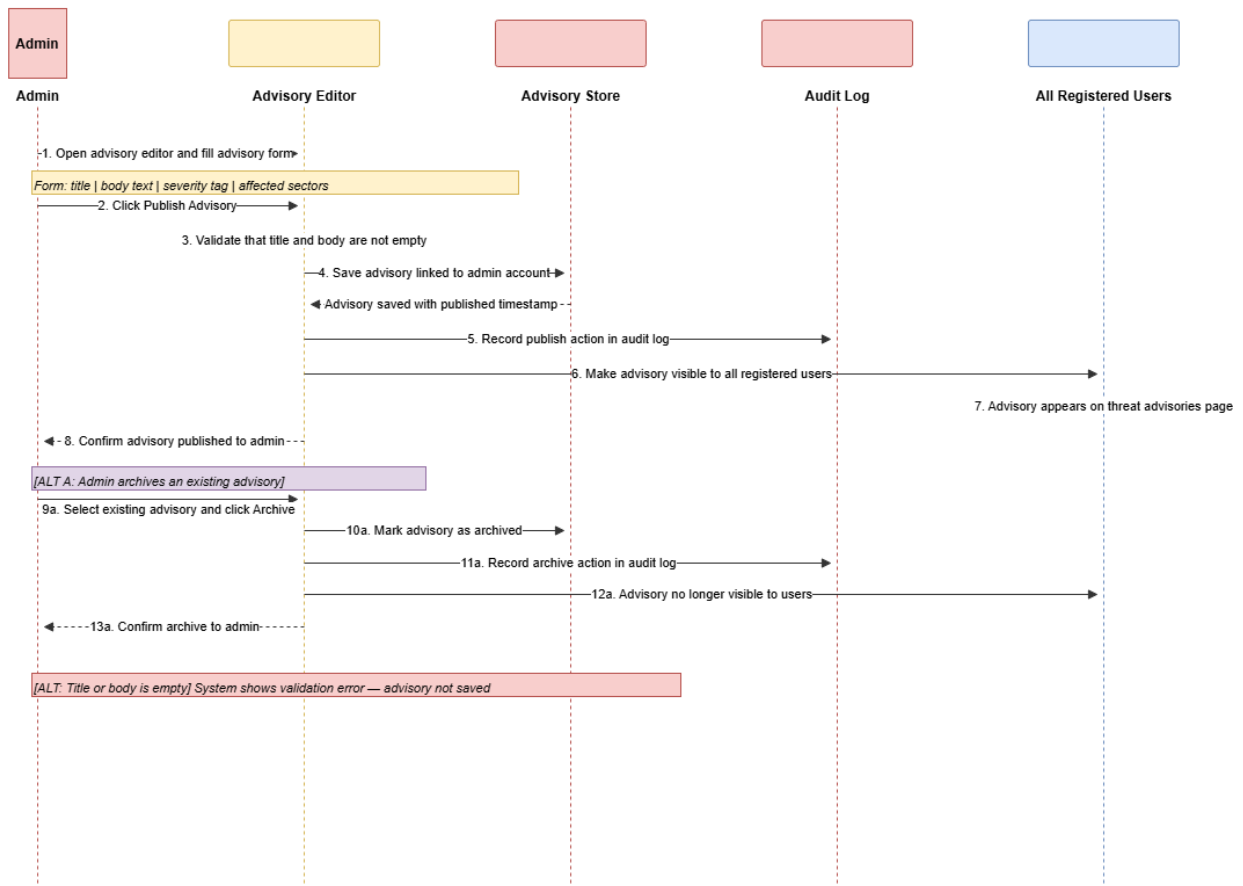
SD-08: User Creates an Alert Subscription (Conceptual)



SD-09 — Admin Posts Threat Advisory

Covers advisory publishing: admin opens the advisory editor, fills the form (title, body, severity tag, affected sectors), clicks publish, the system validates required fields, saves the advisory linked to the admin account, records the action in the audit log, and makes the advisory visible to all registered users. ALT A (archive existing advisory): admin marks an advisory as archived, it is removed from user view and the action is logged. ALT fragment covers empty required fields.

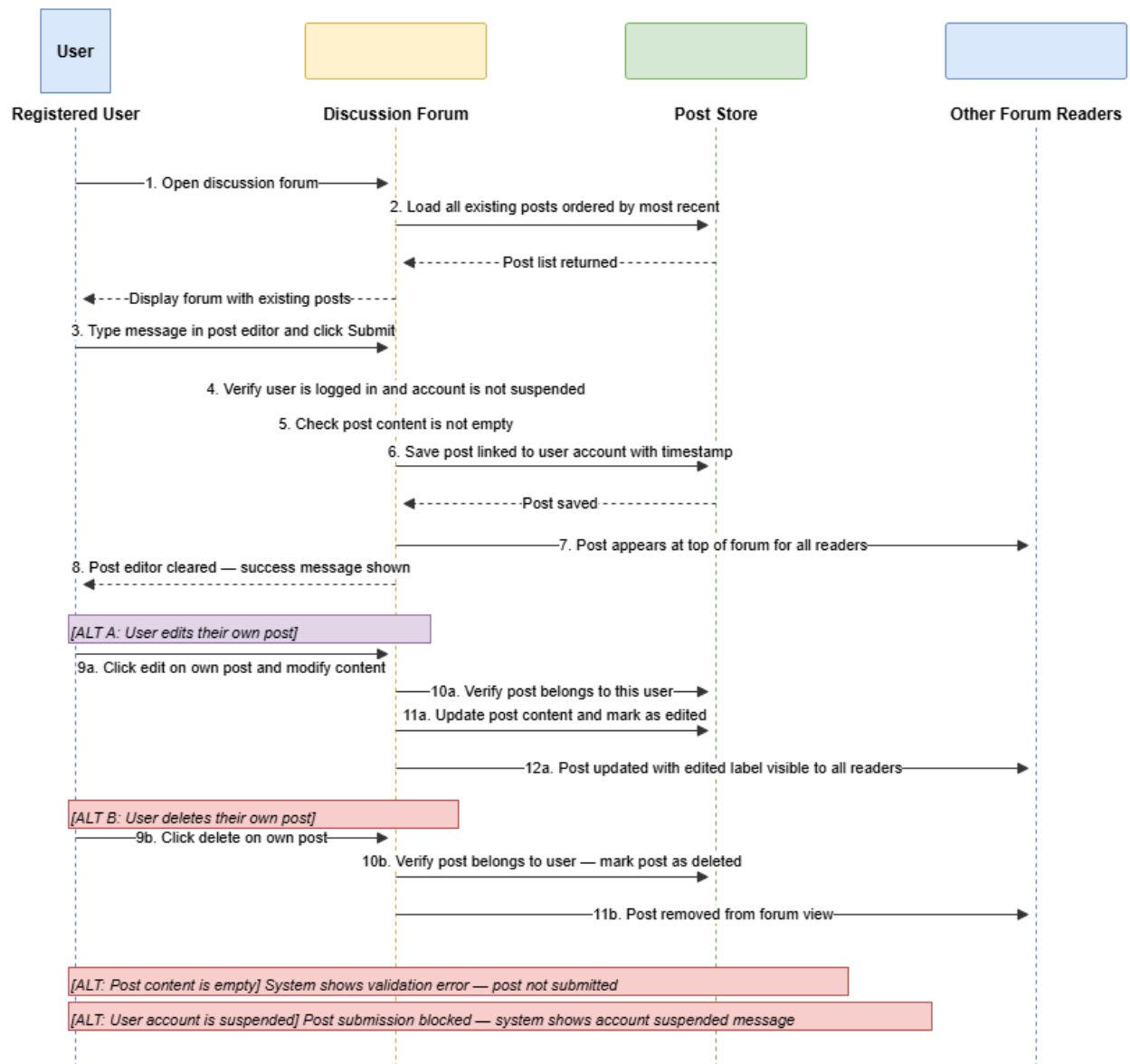
SD-09: Admin Posts Threat Advisory (Conceptual)



SD-10 — User Posts in Discussion Forum

Covers the forum lifecycle: user opens the forum, existing posts are loaded ordered by most recent, user types a message and submits, the system verifies the account is active and content is not empty, saves the post with a timestamp, and the post appears to all forum readers. ALT A (edit post): user edits their own post, system verifies ownership, updates the content and marks the post as edited. ALT B (delete post): user deletes their own post, system verifies ownership, marks it as deleted and removes it from view. ALT fragments cover empty content and suspended account.

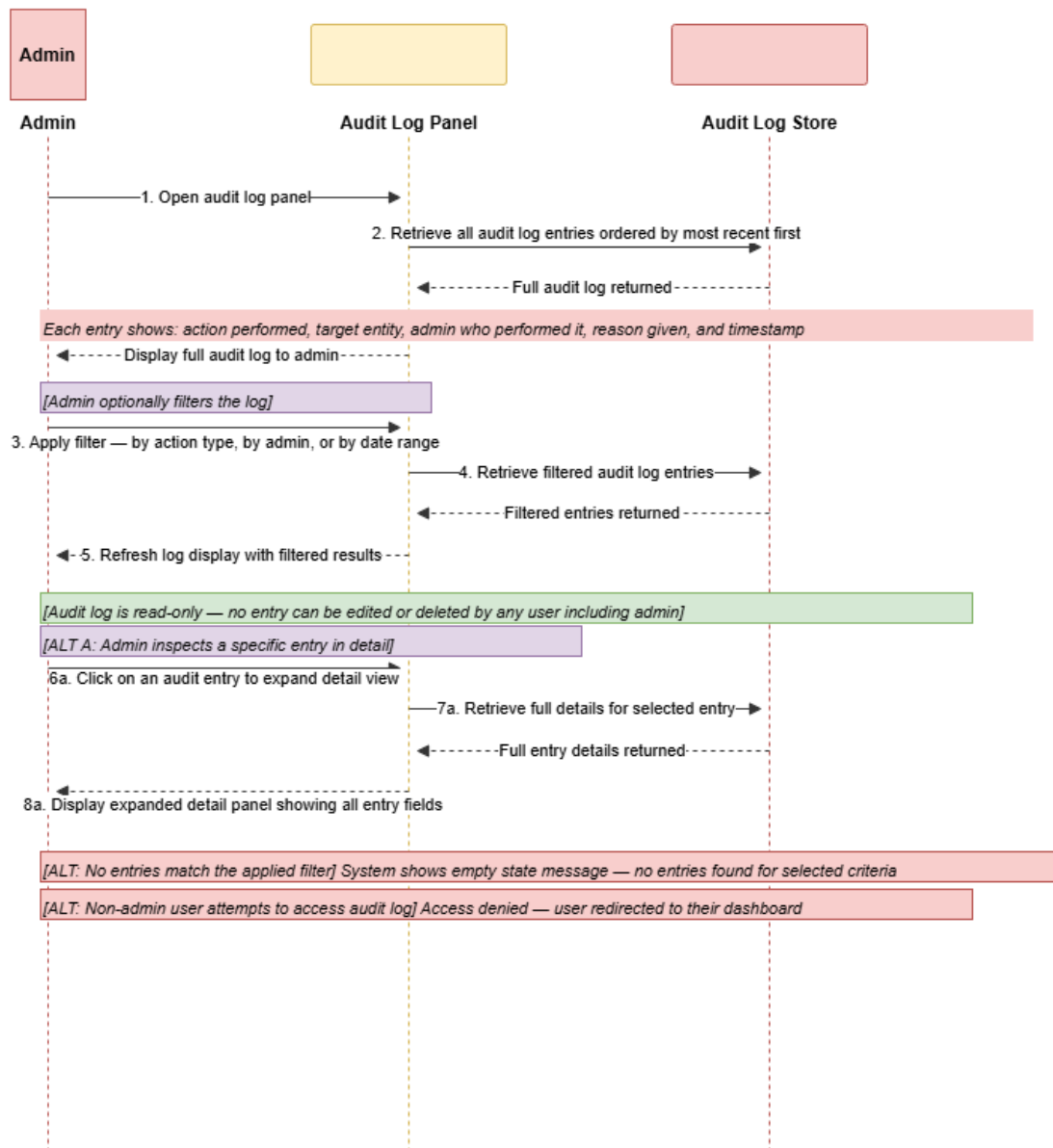
SD-10: User Posts in Discussion Forum (Conceptual)



SD-11 — Admin Views Audit Log

Covers audit log access: admin opens the panel, all entries are retrieved ordered by most recent, the full log is displayed. Admin optionally applies a filter by action type, responsible admin, or date range, triggering a filtered retrieval. Admin optionally expands a specific entry for full detail view. The audit log is read-only at all times for all users including other admins. ALT fragments cover no entries matching the filter and non-admin access attempt. ALT fragments cover no entries matching the filter and non-admin access attempt.

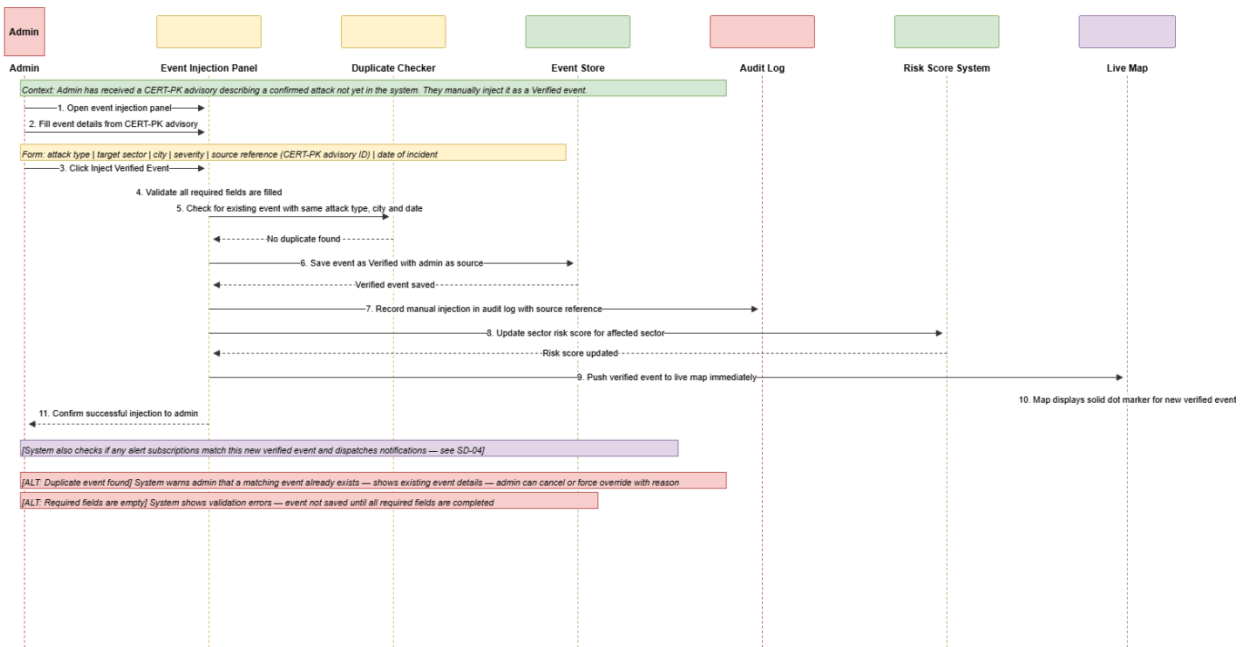
SD-11: Admin Views Audit Log (Conceptual)



SD-12 — Admin Manually Injects Verified Event

Covers manual event injection for CERT-PK advisories not yet in the system: admin opens the event injection panel, fills the form (attack type, sector, city, severity, CERT-PK advisory reference, incident date), the system validates required fields, checks for a duplicate, saves the event as Verified with admin as source, records the injection in the audit log, updates the affected sector risk score, and pushes the event immediately to the live map as a solid-dot Verified marker. ALT fragments cover duplicate found with override option and missing required fields.

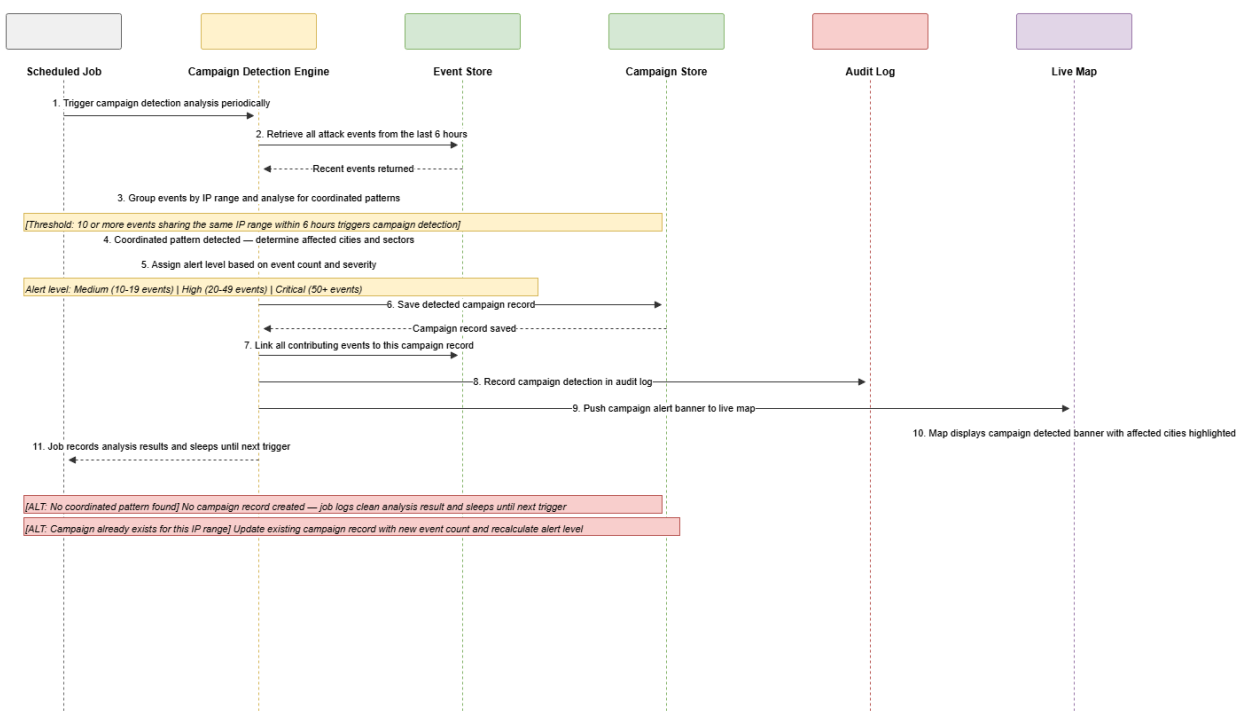
SD-12: Admin Manually Injects a Verified Event (Conceptual)



SD-13 — ML System Detects Coordinated Campaign

Covers the campaign detection pipeline: the scheduled job triggers the campaign detection engine, recent events from the last 6 hours are retrieved, events are grouped by IP range and analysed for coordinated patterns, if 10 or more events share an IP range the threshold is met, the engine calculates the alert level (Medium 10-19, High 20-49, Critical 50 or more), saves a ThreatCampaign record, links all contributing events to the campaign, records the detection in the audit log, and pushes the campaign detected banner to the live map with affected cities highlighted. ALT fragments cover no pattern found (silent end) and updating an existing campaign when new events arrive.

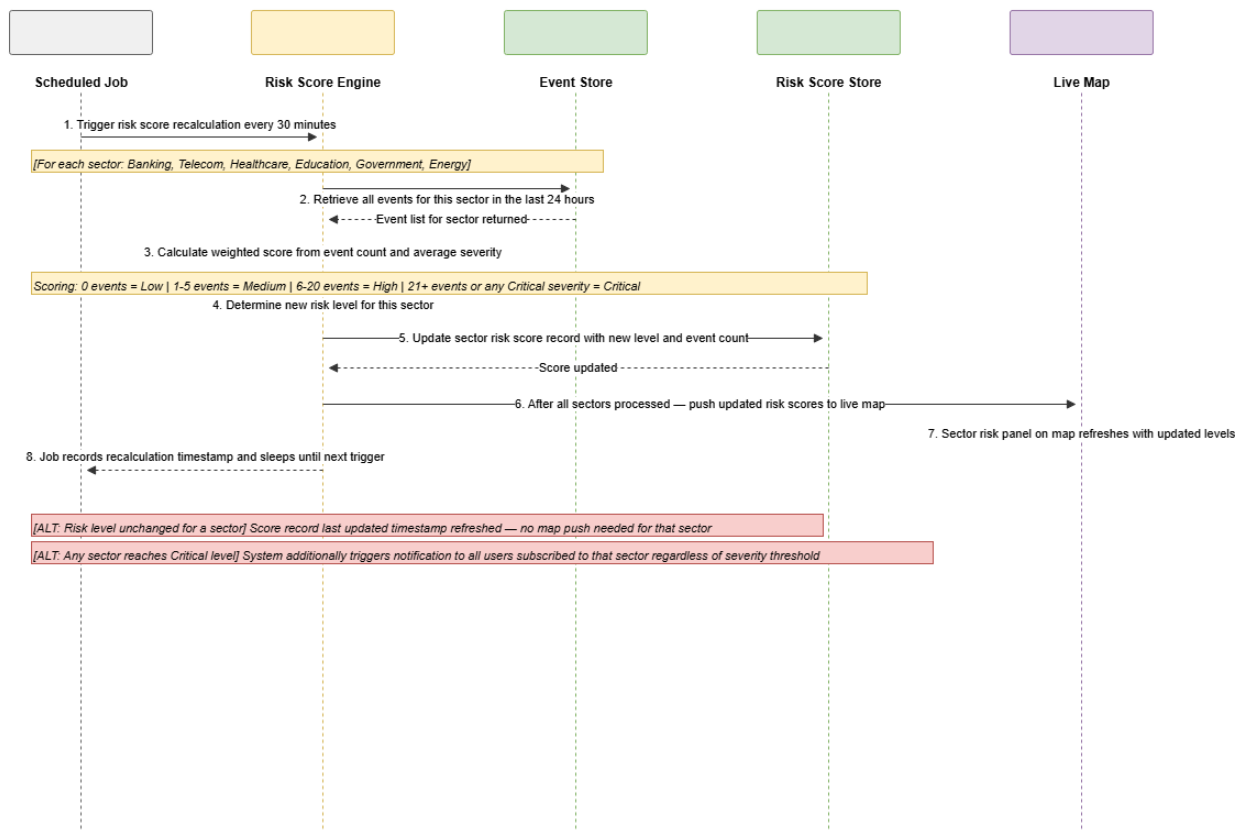
SD-13: ML System Detects Coordinated Attack Campaign (Conceptual)



SD-14 — Sector Risk Score Recalculation

Covers the risk score pipeline: the scheduler triggers the risk score engine every 30 minutes, the engine iterates through all six sectors (Banking, Telecom, Healthcare, Education, Government, Energy), for each sector retrieves events from the last 24 hours, calculates a weighted score from event count and average severity, determines the new risk level, updates the sector risk score record, and after all sectors are processed pushes the updated scores to the live map sector panel. ALT fragment covers risk level unchanged for a sector (timestamp updated but no map push needed) and any sector reaching Critical level triggering broad notifications to all subscribers of that sector.

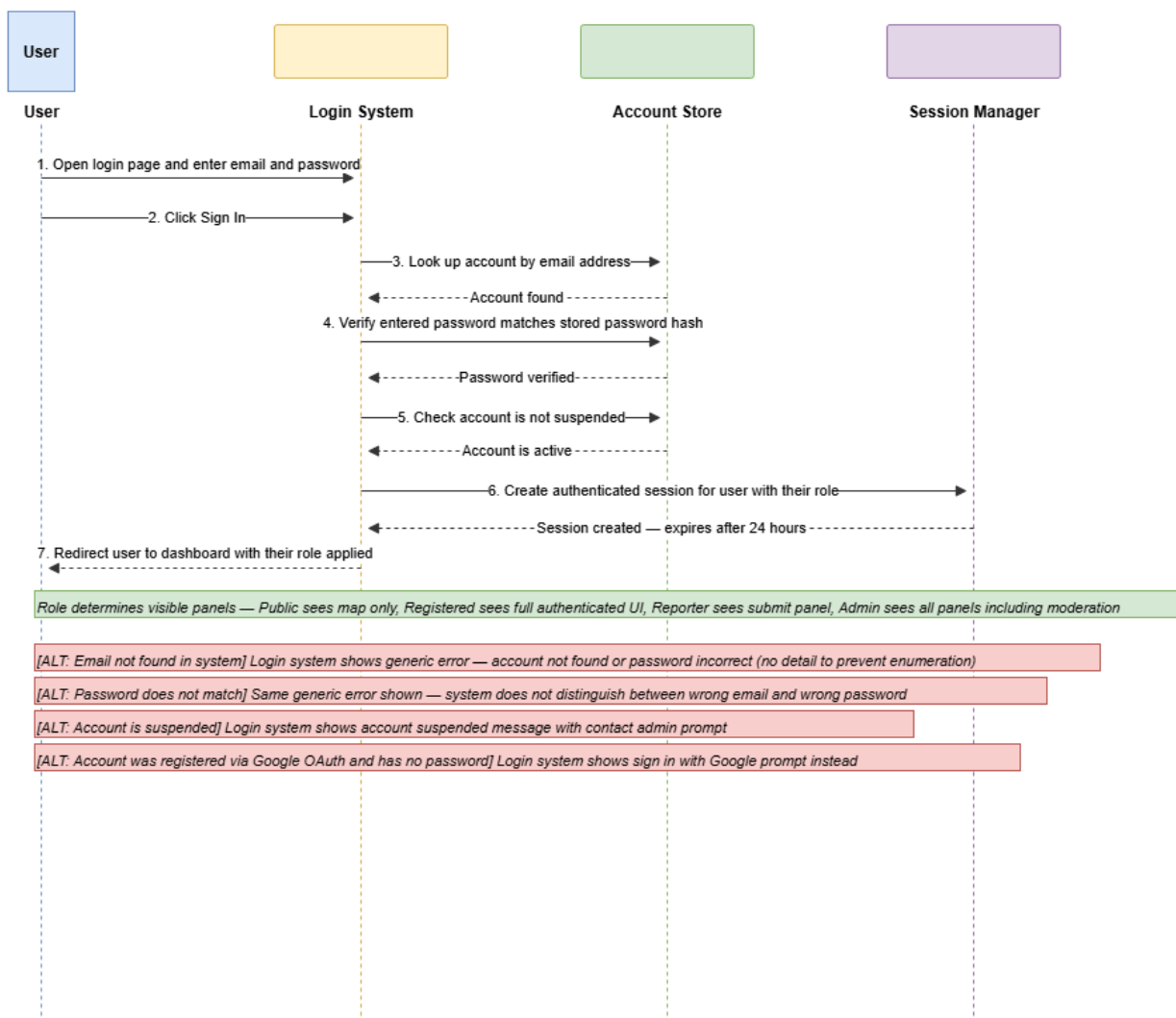
SD-14: Sector Risk Score Recalculation (Conceptual)



SD-15 — User Login with Email and Password

Covers email authentication: user enters credentials on the login page, clicks sign in, the system looks up the account by email, verifies the password against the stored hash, checks the account is not suspended, creates an authenticated session with a 24-hour expiry, and redirects the user to the role-aware dashboard. Panel visibility on the dashboard is determined by the user's role. ALT fragments cover: email address not found in system, password does not match (both show the same generic error to prevent account enumeration), account is suspended, and account was registered via Google OAuth and has no password.

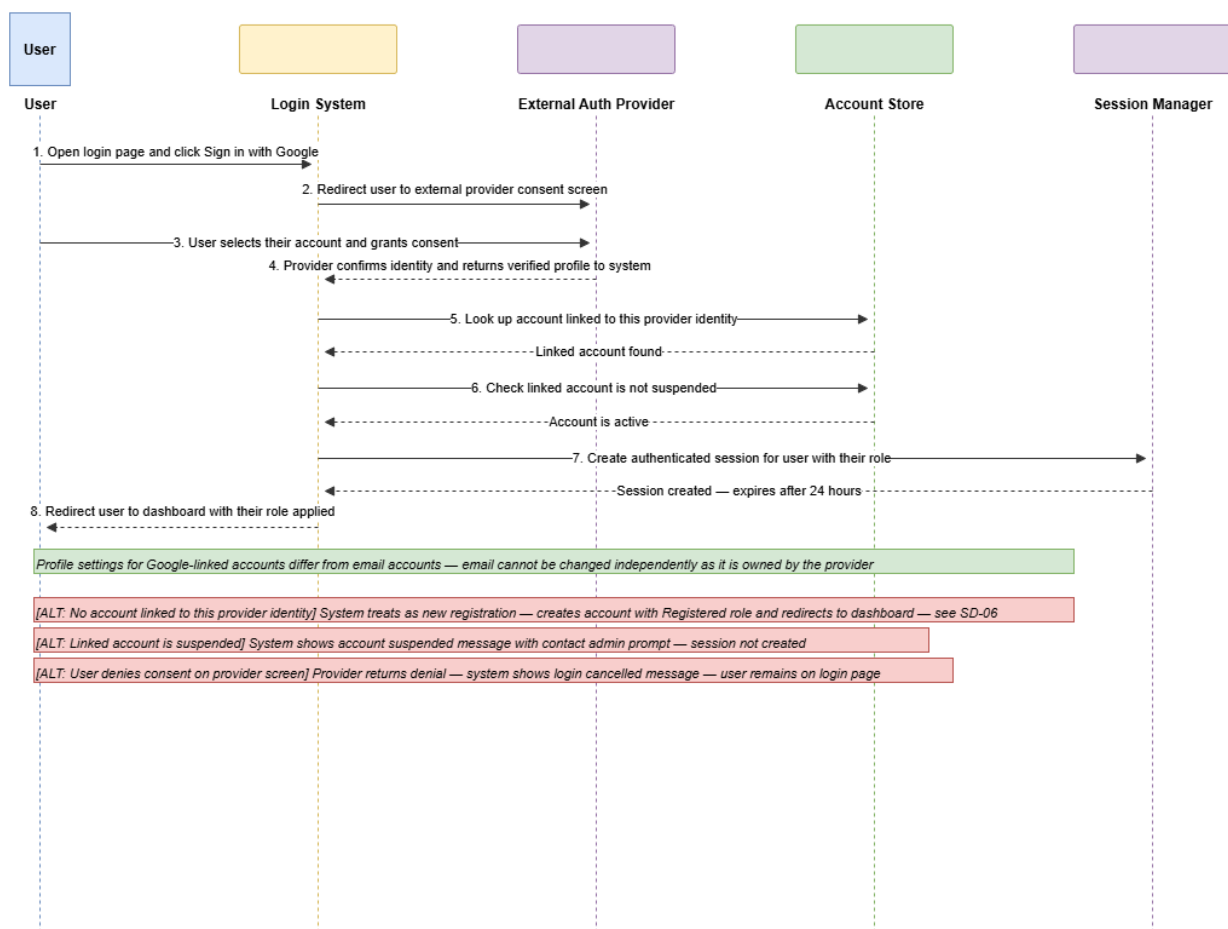
SD-15: User Login with Email and Password (Conceptual)



SD-16 — User Login with Google OAuth

Covers OAuth authentication: user clicks sign in with Google, the login system redirects them to the external provider consent screen, the user selects their account and grants consent, the provider returns a verified identity to the system, the system looks up the account linked to that provider identity, checks the account is not suspended, creates an authenticated session with a 24-hour expiry, and redirects to the role-aware dashboard. Profile settings for Google-linked accounts differ from email accounts — email address cannot be independently changed. ALT fragments cover: no account linked to the provider identity (triggers new account creation as in SD-06), account is suspended, and user denies consent on the provider screen.

SD-16: User Login with Google OAuth (Conceptual)



5. Technology Stack

The following table defines the complete technology stack for ThreatCast PK. Every technology choice is justified by the project requirements — Blazor Server for real-time UI without JavaScript complexity, SignalR for sub-2-second event push, SQL Server for relational integrity, and a Python microservice for ML independence per NFR-15.

Layer	Technology	Justification
UI Framework	Blazor Server (.NET 8)	Component-based UI with server-side rendering; enables SignalR integration natively; no separate JavaScript framework required
Real-Time Push	SignalR	Persistent WebSocket connections enable sub-2-second event push to all connected clients (NFR-02); built into ASP.NET Core
Map Rendering	Leaflet.js (via JS Interop)	Lightweight open-source mapping library; supports tile overlays, custom markers, and real-time updates; free with no API key required
Analytics Charts	Chart.js (via JS Interop)	Responsive chart library for line, bar, pie, and heatmap visualizations; integrates with Blazor via JavaScript Interop
Backend API	ASP.NET Core Web API	RESTful API gateway handling all CRUD operations, authentication, rate limiting, scheduled background jobs (IHostedService)
ML Microservice	Python FastAPI + scikit-learn	Independently deployable service (NFR-15) for Isolation Forest campaign detection and weighted sector risk score calculation
Database	SQL Server Express	Relational DBMS enforcing referential integrity, unique constraints for deduplication (NFR-11), and soft-delete patterns (NFR-12)
ORM	Entity Framework Core	Code-first migrations, LINQ queries, parameterised command generation preventing SQL injection (NFR-06)
Authentication	ASP.NET Core Identity + JWT + Google OAuth	Identity provides password hashing (NFR-05) and role management; JWT tokens expire after 24 hours (NFR-05); Google OAuth delegates credential storage (NFR-05)
Threat Intel API 1	AbuseIPDB (Free Tier)	IP reputation lookups for auto-approval and scheduled Pakistani threat feed (US-16, US-26); free community tier with 1,000 requests/day
Threat Intel API 2	GreyNoise Community API	Classifies internet background noise vs targeted attacks, reducing false positives in the IP verification pipeline
App Hosting	Render.com / Railway (Free Tier)	Zero-cost deployment for Blazor Server application and Python ML microservice; sufficient for evaluation-period load (NFR-04)
DB Hosting	Supabase (Free Tier)	Managed PostgreSQL-compatible database at PKR 0 cost; 500 MB storage sufficient for project evaluation period

Total estimated deployment cost: PKR 0. All services listed above offer permanent free tiers adequate for the project evaluation period.

6. Panel and Feature Access by Role

The following matrix defines which panels and features each user role can access. Roles are hierarchical — Reporter inherits all Registered User access, and Registered User inherits all Public User access. Admin access is independent of the standard hierarchy.

Panel / Feature	Public	Registered	Reporter	Admin
Live Threat Map	Read only	Read only	Read only	Full access
Threat Pulse Live Ticker	Yes	Yes	Yes	Yes
Glossary	Yes	Yes	Yes	Yes
About / How It Works	Yes	Yes	Yes	Yes
Discussion Forum — Read	Yes	Yes	Yes	Yes
Discussion Forum — Post	No	Yes	Yes	Yes
Threat Advisories — Read	No	Yes	Yes	Yes
Threat Advisories — Publish	No	No	No	Yes
My Profile	No	Yes	Yes	Yes
Notification Center	No	Yes	Yes	Yes
Alert Subscriptions	No	Yes	Yes	Yes
Submit Attack Report	No	No	Yes	Yes
My Reports	No	No	Yes	Yes
Moderation Queue	No	No	No	Yes
User Management	No	No	No	Yes
Event Injection Panel	No	No	No	Yes
Audit Log	No	No	No	Yes

7. Future Scope

The following features were identified during the design phase and deliberately scoped out of the current version due to implementation complexity or time constraints. They are documented here as a credible, costed development roadmap for ThreatCast PK beyond the academic evaluation context.

7.1 Premium Organisational Tier

Enterprise subscribers — banks, telecoms, hospitals, government departments — would gain access to a set of premium features not available to standard users. These include bulk CSV and JSON data exports from the event store, a dedicated RESTful threat feed API for integration with internal SIEM systems, custom sector-specific risk reports generated on demand, and extended historical data access beyond the standard 30-day window. This tier would be funded through B2B subscriptions, creating a sustainable revenue model that compensates community reporters and funds ongoing platform development.

7.2 Reporter Incentive and Compensation Programme

Reporters accumulate reputation points for each approved report. Under this future programme, accumulated points would convert to PKR wallet credits funded by premium organisational subscribers. The model mirrors threat intelligence bug bounty platforms such as HackerOne and creates a direct financial incentive for high-quality, timely community reporting across Pakistan — particularly in provincial cities where formal cybersecurity infrastructure is limited.

7.3 Urdu and Regional Language Support

Full Urdu and Roman Urdu UI localisation to improve platform accessibility for users across Pakistan whose primary language is not English. This is particularly important for small business owners, journalists, and civil society users in Sindh, KPK, and Balochistan where English proficiency is lower and the impact of cyberattacks on unprotected organisations is disproportionately high.

7.4 Mobile Application

A companion mobile application for Android and iOS providing push notifications for high-severity events matching a user's saved preferences. The application would integrate with the same backend API as the web platform and would additionally support location-aware threat alerts — warning users in real time when an attack is reported in their current city.

7.5 Direct CERT-PK Advisory Integration

A live parser for the official CERT-PK advisory feed that automatically converts published advisories into verified events without requiring admin manual injection. Currently, the admin must manually read a CERT-PK advisory and inject the event through the event injection panel. A direct integration would eliminate this step, reduce the time between advisory publication and map visibility, and remove a potential point of human error in the event classification process.

7.6 Threat Campaign Attribution

An advanced feature that attempts to attribute detected threat campaigns to known threat actor groups using shared indicators of compromise from open threat intelligence feeds such as MISP and OpenCTI. Attributed campaigns would display a threat actor profile card on the map alongside the campaign alert banner, providing context that defenders and researchers currently have to manually compile from multiple sources.

End of Document · ThreatCast PK · Software Design Document · CS-284L Spring 2026 · Air University Islamabad Campus